

Secure Active Content and Mobile Code Technology Standard

STANDARD NUMBER: DAS-ITS-2100-21-A	EFFECTIVE DATE: 08/12/2021	APPROVED BY: Anupam Srivastava, State Chief Information Security Officer
REPLACES STANDARD DATED: n/a	AUTHORITY: Ohio Revised Code 125.18 Office of Information Technology - duties of director - contracts, Ohio IT Standard ITS-SEC-02, "Security Controls Framework"	

1.0 Purpose

The purpose of this standard is to provide requirements to Ohio Department of Administrative Services (DAS) technical teams that will allow for the consistent implementation of secure **active content** and **mobile code** technology standards across **DAS-managed information systems**.

2.0 Scope

The scope of this standard includes any DAS-managed information system. This standard represents the minimum acceptable secure active content and mobile code standards for applications, operating systems and **web browsers**.

This policy also applies to DAS **data owners**, **service owners**, and to **external service providers**.

3.0 Standard

3.1 Minimum Secure Active Content and Mobile Code Requirements

The following minimum secure active content and mobile code standards shall be applied to information systems that are developed, acquired or maintained by DAS.

3.1.1 Permitted Technologies

- 3.1.1.1 Active content and mobile code technologies having full functionality shall be permitted only where access to the services and resources of a computer platform are mediated or controlled. Examples include Java mobile code and various **scripting languages** running within the confines of a browser.

- 3.1.1.2 Active code and mobile technologies having limited functionality, with no capability for unmediated access to the services and resources of a computing platform shall be permitted.
- 3.1.1.3 **Signed code** from trusted sources shall be permitted.
- 3.1.1.4 **Unsigned code** from trusted sources shall be permitted but is not preferred.
- 3.1.2 Prohibited Technologies
 - 3.1.2.1 Active content and mobile code technologies having broad functionality and unmediated access to the services and resources of a computing platform shall be prohibited. Examples include ActiveX and script languages.
 - 3.1.2.2 Unsigned code from untrusted sources shall be prohibited.
 - 3.1.2.3 Technologies that are no longer supported by the vendor, (i.e., that have reached their end-of-life) shall be prohibited.
- 3.1.3 Web browsers shall be configured to:
 - 3.1.3.1 Restrict the use of downloadable active content.
 - 3.1.3.2 Enable **pop-up blockers** and only allow pop-ups from trusted sources.
 - 3.1.3.3 Enable **phishing** protection, if available.
 - 3.1.3.4 Limit the use of JavaScript, Flash and other active content technologies to **trusted sites**.
- 3.1.4 DAS-managed information systems shall be configured to reduce system functionality to the minimum needed to carry out its mission.
 - 3.1.4.1 Browser-side: Unnecessary **plug-ins** and ActiveX controls on Web browsers shall be removed.
 - 3.1.4.2 Server-side: Unnecessary software code, or scripts shall be removed from servers.
 - 3.1.4.3 **Scripts** shall validate the size and values of input parameters.
 - 3.1.4.4 Scripts shall run with minimal privileges.
- 3.1.5 Whenever possible, **Web content managers** shall convert documents published to the Web to **portable document format (PDF)** or **rich text**

format (.rtf) format.

- 3.1.6 Applications shall be prohibited from running as **root**, or at an operating system administrator level.

3.2 Exception Process

To request an exception to one or more of the requirements outlined in this standard, please complete an IT Security Exception Request Form.

- 3.2.1 The form is located within the IT Enterprise Services Portal under the "Services & Products" category.
- 3.2.2 If you have questions, please contact the DAS Office of Information Security and Privacy (refer to Section 9.0 Inquires for contact information).

4.0 References

- 4.1 **Ohio IT Standard ITS-SEC-02, Security Controls Framework:** This state IT standard specifies the minimum requirements for information security in all agencies and identifies the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53 as the framework for information security controls implementation for the state.
- 4.2 **National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, Security and Privacy Controls for Federal Information Systems and Organizations:** NIST SP 800-53 provides guidelines for selecting and specifying security controls for federal government information systems.
- 4.3 **Ohio Administrative Policy IT-13, Data Classification:** This Ohio administrative policy provides a data classification methodology to state agencies for the purpose of understanding and managing data and information systems with regard to their level of confidentiality and criticality.
- 4.4 **DAS Policy 2100-21, System and Communications Protection Policy:** DAS Policy 2100-21 establishes requirements for managing risks through the establishment of an effective system and communications protection program. The program shall assist DAS in implementing security controls with regard to system configuration and data communication and transfer.
- 4.5 **NIST SP 800-28, Guidelines on Active Content and Mobile Code:** NIST SP 800-28 provides guidelines for securing active content and mobile code for federal government information systems.

5.0 Definitions

<i>Active Content</i>	Electronic documents that can carry out or trigger actions automatically on a computer platform without the intervention of a user. ¹
<i>DAS-managed Information System</i>	Information systems that reside in facilities or infrastructure managed by DAS OIT personnel. Primary responsibility for managing these systems may be assigned to DAS OIT personnel or other outside entities. ²
<i>Data Owner</i>	The data owner is responsible for the identification and classification of information, in consultation with legal counsel, and shall address the assignment of data classification labels, data compilation, data classification coordination, data classification compliance and data access. The role of a data owner and his/her associated responsibilities are addressed in detail within Ohio Administrative Policy IT-13, "Data Classification."
<i>External Service Providers</i>	An entity outside State of Ohio government that provides external information system or service capabilities to DAS by contract.
<i>Mobile Code</i>	Software programs or parts of programs obtained from remote information systems, transmitted across a network, and executed on a local information system without explicit installation or execution by the recipient. ³
<i>Portable Document Format (PDF)</i>	A file format that allows documents to be shared regardless of hardware, software or operating system type. It provides an image of text and/or graphics.
<i>Phishing</i>	A technique for attempting to acquire sensitive data, such as bank account numbers, through a fraudulent solicitation in

¹ Jansen, Wayne A., Theodore Winograd, Karen Scarfone. NIST Special Publication 800-28 Version 2, "Guidelines on Active Content and Mobile Code," U.S. Department of Commerce National Institute of Standards and Technology, March 2008 <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-28ver2.pdf>>.

² *Ibid.*

³ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

email or on a website, in which the perpetrator masquerades as a legitimate business or reputable person.⁴

<i>Plug-in</i>	A plug-in is a piece of software that enables additional functionality.
<i>Pop-up Blocker</i>	A pop-up blocker is software that prevents pop-up windows from appearing on a website.
<i>Rich Text Format</i>	A file format that allows documents to be shared regardless of the platform type.
<i>Root</i>	Running at a root level would allow applications to make any modifications to a system. For example, it would allow an application to read or write to any files, perform operations and even change configurations.
<i>Script</i>	A sequence of instructions, ranging from a simple list of operating system commands to full-blown programming language statements, which can be executed automatically by an interpreter. ⁵
<i>Scripting Language</i>	A definition of the syntax and semantics for writing and interpreting scripts. ⁶
<i>Signed Code</i>	Code that is verified as being from a legitimate source through digital signatures and is confirmed as unaltered after the time of signature. Consequently, indicating that the code is safe for installation.
<i>Service Owner</i>	A service owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.
<i>Trusted Sites</i>	A trusted site is designated as “safe.” The user feels that materials downloaded or run from the website will not cause any harm to IT resources or state data.

⁴ Nieves, Michael, Kelley Dempsey, and Victoria Yan Pillitteri. “NIST Special Publication 800-12 Revision 1, An Introduction to Information Security,” U.S. Department of Commerce National Institute of Standards and Technology, June 2017 < <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-12r1.pdf>>.

⁵ Jansen, Wayne A., Theodore Winograd, Karen Scarfone. NIST Special Publication 800-28 Version 2, “Guidelines on Active Content and Mobile Code,” U.S. Department of Commerce National Institute of Standards and Technology, March 2008 < <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-28ver2.pdf>>.

⁶ *Ibid.*

<i>Unsigned Code</i>	Code that is not signed by the source (e.g., digital signature). Unsigned code is not as easily verified as coming from a trusted, reliable source.
<i>Web Browsers</i>	Client software used to view Web content. ⁷
<i>Web Content Managers</i>	Individuals charged with working with agency business units to create, update, maintain and remove Web content.

6.0 Related Resources

Document Name
<i>Ohio IT Standard ITS-SEC-02, "Security Controls Framework"</i> https://das.ohio.gov/technology-and-strategy/policies
<i>NIST SP 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations"</i> https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
<i>NIST Special Publication 800-28, "Guidelines on Active Content and Mobile Code"</i> https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-28ver2.pdf

7.0 Implementation

- 7.1 DAS data owners and service owners are expected to work towards implementation of the secure active content and mobile code technology standard requirements outlined in this standard as quickly as possible.
 - 7.1.1 For new information systems that are developed or acquired by DAS, the secure active content and mobile code technology standard requirements outlined in this standard shall immediately become effective.
 - 7.1.2 For existing information systems and information system development projects that have moved beyond the requirements phase, DAS data owners and service owners have one year from the effective date of this standard to implement the requirements.
 - 7.1.3 If for some reason a DAS data owner or service owner feels that it is not technically feasible to implement the requirements outlined in this standard, an exception request shall be submitted in accordance with Section 3.2.

⁷ Jansen, Wayne A., Theodore Winograd, Karen Scarfone. NIST Special Publication 800-28 Version 2, "Guidelines on Active Content and Mobile Code," U.S. Department of Commerce National Institute of Standards and Technology, March 2008 < <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-28ver2.pdf>>.

8.0 Revision History

Date	Description of Changes
08/12/2021	Original Standard
08/12/2022	Scheduled standard review.

9.0 Inquiries

For information regarding this DAS IT standard, please contact:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 19th Floor
Columbus, Ohio 43215

Telephone: 614.644.9391

Email: state.isp@das.ohio.gov

Web: <https://das.ohio.gov/technology-and-strategy/information-security-privacy>

DAS IT Standards are online at:

<https://das.ohio.gov/technology-and-strategy/policies>

10.0 Attachments

None.